

UNIVERSIDAD LA SALLE



FACULTAD DE INGENIERÍA

Curso:

Auditoría de Sistemas de Información

PROYECTO FINAL DE AUDITORÍA

Integrantes:

Infa Sánchez, Roger
Mares Graos, Frederick Dicarlo
Ortiz Rosas, Joshua David
Saya Ramos, Arnold Daniel

Arequipa, Perú
Mayo 2026

Índice

1. FASE I: ANÁLISIS INICIAL	3
1.1. Empresa	3
1.1.1. Descripción General	3
1.1.2. Historia	3
1.1.3. Misión	4
1.1.4. Visión	4
1.2. Organigrama	4
1.2.1. Descripción General	4
1.2.2. Niveles Jerárquicos	4
1.2.3. Departamentos y Áreas Funcionales	5
1.2.4. Relaciones de Autoridad	5
1.3. Cantidad De Empleados	5
1.4. Definición De Auditoría	5
1.5. Análisis Detallado	6
1.6. Estructura Del Área A Auditar	6
1.7. Nivel De Riesgo	6
1.8. Áreas Involucradas	7
1.9. Plan De Trabajo Global	7
2. FASE II: PLANIFICACIÓN DE LA OPERACIÓN	8
2.1. Objetivo General	8
2.2. Objetivos Específicos	8
2.3. Fechas	9
2.4. Alcance	9
2.4.1. Ámbito de Estudio	9
2.4.2. Criterios de Inclusión	9
2.4.3. Criterios de Exclusión	10
2.4.4. Posibles Problemas	10
2.4.5. Resultados Esperados	10
2.5. Inventario de Puntos a Tratar	11
2.5.1. 1. Auditoría de Equipos de Red y Comunicación	11
2.5.2. 2. Auditoría de Sistemas Operativos (SO)	12
2.6. Persona Colaboradora	12
2.7. Documentos Requeridos	13
2.8. Plan De Auditoría	13
2.8.1. Investigación Preliminar	13
2.8.2. Recolección De Información	14
2.8.3. Aplicación De Instrumentos	14
2.8.4. Ejecución De Pruebas Técnicas	14
2.8.5. Proceso De Análisis De Evaluación De Riesgos	14
2.8.6. Tratamiento De Riesgo	15

3. FASE III: DESARROLLO DE LA AUDITORÍA	16
3.1. Proceso De Recolección De Información Y Planteamiento De Actividades . .	16
3.2. Aplicación De Instrumentos Para El Levantamiento De Información	16
3.2.1. Cuestionarios y Encuestas	16
3.2.2. Revisión de Documentación	16
3.2.3. Observación	16
3.3. Aplicación De Técnicas Y Herramientas Para El Levantamiento De Actividades	17
3.3.1. Matriz DAFO	17
3.3.2. Matriz de Actividades	17
3.3.3. Matriz de Brechas	17
3.4. Valoración Del Riesgo	18
3.5. Matriz De Riesgo	18
3.6. Matriz De Probabilidad E Impacto	18
3.7. Impacto Económico	19
4. FASE IV: INFORME DE AUDITORÍA	19
4.1. Carta de presentación del informe	20
4.2. Introducción al informe final	20
4.3. Principales Observaciones	20
4.4. Plan de Acción	20
4.5. Plan de Mejoras	20
5. CONCLUSIONES	20
6. RECOMENDACIONES	20

1. FASE I: ANÁLISIS INICIAL

Esta primera fase establece las bases contextuales y estructurales del proyecto de auditoría de sistemas. En ella se define el perfil de la organización beneficiaria (**ACIDE**), detallando su trayectoria histórica, su organigrama funcional y la composición de sus recursos humanos. Asimismo, se delimita formalmente el alcance de la auditoría sobre el área de Digitales y Marketing, analizando la arquitectura tecnológica local que soporta su operatividad y ponderando de forma preliminar las brechas de seguridad físicas y lógicas que sustentan la definición del nivel de riesgo.

1.1. Empresa

1.1.1. Descripción General

ACIDE es la *Asociación Civil de Investigación para el Desarrollo y la Empresa*. Es una consultora que impulsa el desarrollo empresarial y fortalece capacidades en los sectores público y privado. Cuenta con más de una década de experiencia en proyectos de consultoría y digitalización, asesorías estratégicas, transferencia de tecnología e iniciativas innovadoras, con respaldo de certificación ISO y un equipo multidisciplinario orientado a la excelencia.

Ofrece cuatro líneas de servicio: **asesoría** (orientación personalizada para desafíos y decisiones estratégicas), **consultoría** (análisis y soluciones para mejorar eficiencia y desempeño), **capacitación** (formación práctica para equipos de trabajo) y **digitalización** (herramientas tecnológicas para modernizar operaciones internas y externas).

1.1.2. Historia

2008 — MTPE proveedor. Inicio de actividades en la zona sur del país; desarrollo de 50 planes de negocio en Puno y Arequipa mediante el Programa NIE (Nuevas Iniciativas Empresariales), en el marco del Ministerio de Trabajo y Promoción del Empleo.

2013 — Alianzas estratégicas y convenios. ACIDE se constituye como aliado estratégico del OSCE, capacitando a funcionarios en contrataciones del Estado; firma convenio con la GREA (Arequipa) para formar a docentes y personal administrativo en gestión pública y educativa.

2016 — Reconocimientos y certificación de calidad. El OSCE reconoce a ACIDE como aliado estratégico y la ubica entre las cuatro principales capacitadoras del sector logístico a nivel nacional. Obtiene certificación ISO 9001 por su gestión en atención al cliente, proyectos, asesoría y capacitación en sectores públicos y privados.

2018 — Expansión y distinciones. Creación del Centro Técnico Productivo PROIN-TEC (Resolución Gerencial Regional N° 0685); mención INNOVATE Perú como consultora de mayor trascendencia nacional; alianzas con universidades La Salle, UNSA y San Martín de Porres.

2023 — Congreso de la República. Reconocimiento por trayectoria y contribución al desarrollo sostenible del país, destacando valores y principios de práctica empresarial ética y responsable.

2024 — Municipalidad Provincial de Arequipa. Reconocimiento por esfuerzo, innovación y excelencia emprendedora y por el impacto en el desarrollo económico y social.

1.1.3. Misión

Crear la pronta solución para las necesidades empresariales, brindando la mejor calidad, respuesta, cooperación, ética profesional e innovación del mercado. Como asociación civil sin fines de lucro, mediante asesoría, consultoría, capacitación y monitoreo promueve la investigación y el desarrollo institucional y empresarial en distintos sectores económicos.

1.1.4. Visión

La historia de ACIDE refleja un compromiso con la innovación, la calidad y la ética para impulsar el desarrollo empresarial. Los valores que orientan esta visión incluyen innovación, compromiso, transparencia, adaptabilidad, colaboración y calidad en las relaciones con los clientes y en cada solución ofrecida.

1.2. Organigrama

1.2.1. Descripción General

La estructura organizacional de **ACIDE** se define como una organización funcional y jerárquica. La empresa centraliza la toma de decisiones en la Gerencia General, delegando la operatividad a jefaturas de área especializadas. Se observa una comunicación vertical donde las directrices estratégicas descienden hacia los colaboradores a través de mandos medios.

1.2.2. Niveles Jerárquicos

Se identifican tres niveles principales de jerarquía dentro de la organización:

1. **Nivel Estratégico:** Representado por la Gerencia General, responsable de la visión global y objetivos a largo plazo.

2. **Nivel Táctico:** Compuesto por los Jefes de Área (Consultoría, Comercial, Planificación, Digitales y Marketing). En el área específica a auditar, este nivel incluye una Jefatura y una Subjefatura que actúa como nexo de comunicación.
3. **Nivel Operativo:** Integrado por los colaboradores y especialistas encargados de la ejecución técnica de los proyectos.

1.2.3. Departamentos y Áreas Funcionales

La empresa se divide en cinco pilares operativos:

- **Consultoría:** Asesoría especializada a clientes.
- **Comercial:** Gestión de ventas y captación de mercado.
- **Planificación:** Gestión de recursos y tiempos.
- **Digitales y Marketing:** Área objeto de la auditoría, enfocada en la digitalización externa y presencia de marca.

1.2.4. Relaciones de Autoridad

Existe una autoridad lineal directa. Los colaboradores reportan directamente a la Subjefatura y Jefatura de Digitales. La comunicación de directrices se realiza de forma escalonada, asegurando que los comunicados oficiales de la jefatura sean transmitidos y supervisados por la subjefatura antes de llegar al personal operativo.

1.3. Cantidad De Empleados

La organización cuenta con un capital humano total de **37 empleados**. El área de Digitales y Marketing, la cual es el foco de este estudio, está compuesta por **12 integrantes** (incluyendo mandos medios y personal operativo). Todo el personal labora bajo la modalidad **100 % presencial** en las instalaciones de la empresa.

1.4. Definición De Auditoría

La presente auditoría se define como una evaluación sistemática, crítica y objetiva de los controles de seguridad, eficiencia operativa y gestión de datos en el área de Digitales. El proceso busca verificar que el uso de herramientas como Nextcloud y los flujos de trabajo en Jira cumplan con estándares de integridad y confidencialidad.

1.5. Análisis Detallado

El análisis de arquitectura de TI de la organización revela una coexistencia híbrida y crítica entre servicios alojados en la nube y recursos locales:

- **Servicios Cloud (SaaS):** El entorno de seguimiento Jira Cloud, el repositorio de versionado de software y las instancias de parametrización en Odoo Studio operan bajo servicios en la nube contratados.
- **Servicios Locales (On-Premises):** El servidor de gestión documental de proyectos, las copias de seguridad locales y la mensajería interna residen en una instancia local del software libre **Nextcloud**. Dicho servidor Nextcloud está montado como un contenedor Docker virtualizado en el entorno local de la oficina, operando sobre un hipervisor PROXMOX VE de un servidor físico ensamblado.

El principal problema reside en que no existe un límite de seguridad o segmentación de red corporativa claro entre las estaciones de trabajo locales (ordenadores personales que ejecutan Ubuntu 22.04 LTS y Windows) y el servidor Nextcloud. Cualquier vulnerabilidad en el firewall del router local o una intrusión en una de las estaciones de trabajo de los desarrolladores expone el acceso de red directa al servidor documental de la empresa, comprometiendo no solo el código fuente propietario de los clientes, sino también la información de los contratos vigentes de digitalización empresarial.

1.6. Estructura Del Área A Auditar

El área de Digitales se estructura bajo la metodología ágil **Scrum**.

- **Gestión de Tareas:** Se utiliza la herramienta **Jira** para el seguimiento de sprints y backlog.
- **Foco Operativo:** Digitalización externa a nivel nacional. No se realizan tareas de soporte técnico interno (IT tradicional), sino que el equipo está volcado netamente a la implementación de soluciones digitales para terceros.

1.7. Nivel De Riesgo

El nivel de riesgo inicial de la infraestructura del área de Digitales se califica preliminarmente como **Alto**. Esta ponderación se fundamenta en la criticidad de los activos de información expuestos en el servidor local de Nextcloud (donde reside el 100 % de los entregables y la documentación de las consultorías activas del proyecto de digitalización de

clientes). A partir del análisis preliminar, se identifican las siguientes brechas y vectores de riesgo:

- **Compromiso de Privacidad de Datos y Propiedad Intelectual:** Riesgo alto de exfiltración de planos de arquitectura, credenciales maestras y documentación confidencial del cliente, debido a la ausencia de políticas de cifrado de almacenamiento y a la falta de mecanismos avanzados de autenticación (como MFA) en el Nextcloud local.
- **Inseguridad en las Estaciones de Trabajo (Endpoints):** Estaciones de desarrollo locales ejecutando comandos con privilegios elevados y descargando paquetes de terceros sin un repositorio local controlado, lo que facilita la introducción involuntaria de código malicioso o dependencias vulnerables.
- **Falta de Control de Acceso Perimetral y Segmentación de Red:** Inexistencia de segmentación VLAN entre la red regular de la oficina (tráfico administrativo) y el segmento de red donde residen el hipervisor PROXMOX y los contenedores del servidor Nextcloud. Esto expone los activos críticos del área ante cualquier ataque de suplantación ARP o de movimiento lateral dentro de la red inalámbrica local.

1.8. Áreas Involucradas

- Jefatura de Digitales y Marketing.
- Equipo de Desarrollo y Digitalización (Colaboradores).
- Infraestructura de Red Interna.

1.9. Plan De Trabajo Global

El plan se divide en cuatro fases:

1. **Levantamiento:** Entrevistas con el equipo y mapeo de la red local.
2. **Evaluación Técnica:** Auditoría de permisos en Nextcloud y revisión de seguridad en estaciones de trabajo (Ubuntu).
3. **Análisis de Procesos:** Revisión de la gestión en Jira y flujos de trabajo en Odoo Studio.
4. **Informe:** Entrega de recomendaciones para blindar la red interna y optimizar la digitalización.

2. FASE II: PLANIFICACIÓN DE LA OPERACIÓN

Esta segunda fase establece la directriz metodológica y la planificación técnica que gobiernan el desarrollo de la auditoría. En ella se determinan el objetivo general, los objetivos específicos y el horizonte temporal de la evaluación. Asimismo, se detalla el alcance operativo y tecnológico mediante criterios explícitos de inclusión y exclusión de activos. Finalmente, se definen los puntos de control clave a auditar en redes y sistemas operativos, las personas colaboradoras, la documentación requerida y el plan de pruebas de seguridad diseñado bajo los estándares internacionales ISO/IEC 27005 e ISO/IEC 27002.

2.1. Objetivo General

Evaluar los procesos operativos del área de Tecnologías de la Información en la empresa **ACIDE**, con un enfoque crítico en el ciclo de vida de desarrollo de software (SDLC), la personalización de soluciones Odoo y la madurez de sus prácticas **DevOps**. Todo esto con el fin de garantizar la eficiencia técnica, la seguridad de la infraestructura local y la robustez en la entrega continua de servicios digitales.

2.2. Objetivos Específicos

- **Optimización de Procesos:** Analizar los flujos de trabajo actuales en el desarrollo de software y digitalización para identificar cuellos de botella y proponer mejoras en la productividad del equipo técnico.
- **Auditoría de Infraestructura Física:** Evaluar el estado, configuración y rendimiento del servidor local, estaciones de trabajo (PCs de escritorio), laptops y periféricos, asegurando que soporten las demandas de compilación y despliegue de software.
- **Seguridad y Control Interno:** Verificar los protocolos de acceso, gestión de secretos y respaldo de información en el servidor local para prevenir la pérdida de propiedad intelectual y código fuente de los clientes.
- **Evaluación de Entornos de Desarrollo:** Revisar las metodologías aplicadas en la personalización de Odoo y desarrollo a medida, asegurando que cumplen con estándares de calidad, mantenibilidad y escalabilidad.
- **Auditoría de Prácticas DevOps y CI/CD:** Evaluar la efectividad de las tuberías (pipelines) de **Integración Continua y Despliegue Continuo**, verificando el uso de

herramientas de automatización, gestión de contenedores, pruebas automatizadas y el control de versiones para optimizar los lanzamientos a producción.

2.3. Fechas

El proyecto de auditoría tiene una duración prevista de **14 semanas**. Se ha establecido un cronograma estimado que considera las fases de planificación, ejecución y entrega de resultados en el siguiente periodo:

- **Fecha de Inicio Estimada:** 06 de abril de 2026.
- **Fecha de Ejecución:** 13 de abril de 2026.
- **Fecha de Finalización Estimada:** 16 de julio de 2026.

Este periodo incluye el levantamiento de información en campo, pruebas de estrés a la infraestructura y la redacción del informe final con el plan de mejora de procesos.

2.4. Alcance

2.4.1. Ámbito de Estudio

La auditoría se circunscribe exclusivamente a las operaciones realizadas de manera presencial en las instalaciones de **ACIDE**. El estudio abarca el ciclo de vida de los proyectos de desarrollo de software a medida, con especial énfasis en la configuración, personalización y despliegue de módulos en el ecosistema **Odoo**. Se evaluará tanto el flujo de trabajo del personal técnico como la interacción con la infraestructura local.

2.4.2. Criterios de Inclusión

Se auditarán los siguientes activos y procesos técnicos:

- **Entorno de Virtualización:** Configuración de contenedores **Docker** y orquestación de despliegues.
- **Pipeline CI/CD:** Revisión de la automatización en el servidor **Jenkins** alojado en el VPS.
- **Sistemas Operativos:** Servidores y estaciones de trabajo bajo la distribución **Ubuntu LTS**.
- **Repositorios y Versionado:** Gestión de ramas y calidad de código en el desarrollo de software.

- **Infraestructura Física:** Servidor local, laptops de desarrollo, impresoras y conectividad de red del área.

2.4.3. Criterios de Exclusión

Quedan fuera del alcance de esta auditoría:

- Áreas administrativas, comerciales y de marketing de la empresa.
- Gestión financiera y estados contables.
- Dispositivos personales de los empleados que no sean utilizados para fines laborales.
- Soporte técnico a clientes finales fuera de la etapa de despliegue inicial.

2.4.4. Posibles Problemas

Se identifican los siguientes riesgos para la ejecución del proyecto:

- **Disponibilidad del Personal:** Alta saturación y carga laboral de los integrantes del área de **Digitales** debido a la simultaneidad de proyectos, lo que podría limitar el tiempo para entrevistas y pruebas.
- **Continuidad Operativa:** Riesgo de interrupción mínima durante las pruebas de estrés en el servidor local o el VPS de producción.
- **Acceso a Información:** Posibles retrasos en la obtención de credenciales de administración para la revisión de logs en Jenkins o Docker.

2.4.5. Resultados Esperados

La culminación de este proceso de auditoría proporcionará a la alta gerencia de **ACIDE** y al equipo de **Digitales** un conjunto de entregables técnicos orientados a la mejora operativa. Se espera obtener:

- **Informe Detallado de Hallazgos y Deficiencias:** Un catálogo formal de errores detectados en la configuración de contenedores Docker, debilidades en los pipelines de Jenkins y vulnerabilidades en la infraestructura de servidores Ubuntu LTS.
- **Análisis de Brechas Tecnológicas (Gap Analysis):** Un diagnóstico que compare el estado actual de los despliegues y el desarrollo de software frente a las mejores prácticas internacionales de la industria (DevOps y seguridad de la información).

- **Matriz de Priorización de Riesgos:** Una clasificación de los errores encontrados basada en su impacto económico y operativo, permitiendo a la empresa identificar qué correcciones requieren atención inmediata.
- **Guía de Recomendaciones Estratégicas:** Propuestas técnicas concretas para la optimización de la integración continua (CI) y la entrega continua (CD), orientadas a reducir la saturación del equipo técnico mediante la automatización efectiva.
- **Base de Conocimiento para Mejora de Procesos:** Documentación técnica que servirá como hoja de ruta para estandarizar el desarrollo a medida y asegurar que las implementaciones de Odoo sean escalables y seguras a largo plazo.

2.5. Inventario de Puntos a Tratar

Basado en la naturaleza de **ACIDE** como consultora orientada a la excelencia y digitalización, el presente inventario define los componentes críticos a inspeccionar. El objetivo es garantizar que la infraestructura tecnológica soporte los estándares de certificación ISO y proteja la información estratégica de sus clientes en los sectores público y privado.

2.5.1. 1. Auditoría de Equipos de Red y Comunicación

Se enfoca en asegurar que el hardware de red (routers, switches y firewalls) gestione el tráfico de datos de manera segura y eficiente.

- **Puntos a Auditar:**
 - **Archivos de configuración y versiones:** Revisión de firmware y parámetros actuales de los dispositivos de red.
 - **Segmentación y Firewalls:** Evaluación de zonas de seguridad (VLANs) y reglas de filtrado de tráfico.
 - **Protocolos de Comunicación:** Verificación del uso de protocolos seguros (SSH, SNMPv3, HTTPS) frente a versiones vulnerables.
 - **Gestión de Cambios:** Control de bitácoras y registros de modificaciones en la infraestructura.
- **Justificación:** Se audita para minimizar riesgos de acceso no autorizado, detectar vulnerabilidades críticas documentadas (NVD) y asegurar que la red cumpla con las políticas de seguridad interna.

2.5.2. 2. Auditoría de Sistemas Operativos (SO)

Este punto evalúa el software base que soporta las operaciones de consultoría, capacitación y digitalización de la empresa.

- **Puntos a Auditar:**

- **Configuración vs. Políticas:** Comparación del estado actual de los servidores frente al estándar de seguridad de la organización.
- **Protección de Endpoints:** Estado y configuración de antivirus y firewalls de host administrados centralizadamente.
- **Gestión de Parches:** Verificación de que el SO cuente con las últimas actualizaciones de seguridad críticas.
- **Servicios y Aplicaciones:** Identificación de servicios innecesarios activos que puedan ampliar la superficie de ataque.
- **Tareas Programadas:** Revisión de procesos automáticos para descartar persistencias maliciosas.
- **Directorio Activo (AD):** Gestión de identidades, privilegios de usuario y políticas de contraseñas.

- **Justificación:** Los sistemas mal configurados o desactualizados facilitan vectores de ataque. La auditoría garantiza un entorno estandarizado, reduce la complejidad administrativa y asegura la trazabilidad de las operaciones.

2.6. Persona Colaboradora

Para el desarrollo de esta auditoría, se ha designado un canal de comunicación directo con el personal estratégico del área de Digitales. La colaboración principal proviene de:

- **Alex Flores Valdez (Encargado de TI - Área de Digitales):** Actúa como el facilitador principal de información técnica y operativa. Su participación es fundamental para:
 - Proveer acceso a las configuraciones de seguridad y privilegios del servidor **Nextcloud**.
 - Facilitar el inventario técnico de las estaciones de trabajo bajo entorno **Ubuntu**.
 - Explicar los flujos de conectividad de la red interna para la evaluación de la privacidad de los datos.

- Coordinar la revisión de las licencias y accesos a las plataformas en la nube (**Odoo Studio**).
- **Personal Operativo de Digitalización:** Colaboradores del área que participarán de manera indirecta mediante la observación de sus procesos diarios y el uso de las herramientas de gestión de tareas en **Jira**.

2.7. Documentos Requeridos

Para la ejecución efectiva de esta auditoría, se solicitará a la Jefatura de Digitales la siguiente documentación y accesos:

- **Esquemas de Red y Arquitectura:** Diagramas topológicos preliminares elaborados en Excalidraw por el equipo técnico.
- **Accesos al Hipervisor:** Credenciales de lectura al entorno **PROXMOX VE**, necesario para auditar la asignación de recursos (vCPU, RAM, almacenamiento) tanto del nodo host como de las máquinas virtuales (VMs) y contenedores LXC.
- **Políticas de Copias de Seguridad:** Documentación (formal o informal) sobre la frecuencia y destino de los respaldos de las máquinas virtuales y del servidor Nextcloud.
- **Inventario de Hardware:** Especificaciones técnicas detalladas del servidor local (placa base, procesador, tipo y estado de los discos de almacenamiento).

2.8. Plan De Auditoría

El proceso de auditoría se enmarca metodológicamente en las directrices de la norma internacional **ISO/IEC 27005** para la gestión de riesgos de seguridad de la información, y adopta controles específicos de la guía de buenas prácticas de **ISO/IEC 27002** (particularmente el Dominio 8 sobre Seguridad Operativa y el Dominio 5 sobre Controles de Acceso). El plan se estructura detalladamente en las siguientes fases operativas:

2.8.1. Investigación Preliminar

Se recopilarán los diagramas de red en Excalidraw y las políticas internas vigentes. Se llevará a cabo un reconocimiento inicial pasivo de los puertos abiertos desde el segmento inalámbrico local hacia el servidor físico.

2.8.2. Recolección De Información

Entrevistas técnicas presenciales con el encargado de TI (Alex Flores) y revisión de los logs del hipervisor PROXMOX VE. Se inspeccionará físicamente el cableado y el estado de refrigeración y suministro de energía del servidor local.

2.8.3. Aplicación De Instrumentos

Uso de listas de verificación de controles basadas en CIS Controls (versión 8) y cuestionarios semiestructurados para evaluar la madurez de la gestión de accesos en Odoo Studio y la política de snapshots en Proxmox.

2.8.4. Ejecución De Pruebas Técnicas

Para verificar empíricamente la solidez de la infraestructura local, se ejecutarán las siguientes pruebas técnicas controladas:

- **Escaneo de Puertos y Vulnerabilidades:** Ejecución de escaneos dirigidos sobre las direcciones IP locales de la subred del hipervisor (192.168.10.0/24) y los contenedores LXC usando las herramientas **Nmap** y **OpenVAS** para identificar servicios expuestos.
- **Pruebas de Estrés y Desempeño de Discos (Storage Benchmark):** Ejecución de pruebas de carga de I/O aleatorio usando la herramienta **fio** en el disco físico mecánico del host, analizando métricas de latencia de escritura y degradación física (valores SMART).
- **Análisis de Configuración de Contenedores Docker:** Ejecución de análisis estáticos sobre las imágenes base y archivos Compose de Odoo y Nextcloud locales mediante la herramienta **Trivy** para detectar secretos embebidos e inyecciones de vulnerabilidades conocidas.
- **Simulación de Recuperación ante Desastres (Test DRP):** Clonación y restauración programada de una máquina virtual (LXC Nextcloud) en un almacenamiento alternativo, con la finalidad de medir el Tiempo Objetivo de Recuperación (RTO) real frente al teórico.

2.8.5. Proceso De Análisis De Evaluación De Riesgos

Evaluación cuali-cuantitativa basada en la probabilidad de ocurrencia e impacto de las brechas detectadas en la fase de pruebas técnicas, clasificando los riesgos en una matriz de prioridad.

2.8.6. Tratamiento De Riesgo

Elaboración del catálogo de acciones recomendadas y soluciones técnicas para la reducción del riesgo a un nivel residual aceptable para la gerencia general de ACIDE.

3. FASE III: DESARROLLO DE LA AUDITORÍA

Esta tercera fase detalla el trabajo de campo y la ejecución práctica de la auditoría sobre la infraestructura del área. Comprende la recopilación de información empírica a través de cuestionarios, encuestas con el personal técnico y la observación sistemática de las condiciones operativas de los servidores y estaciones de trabajo. Asimismo, los hallazgos son evaluados formalmente utilizando herramientas de diagnóstico estratégico como la matriz DAFO, análisis de brechas e identificación y valorización cuali-cuantitativa de riesgos. Finalmente, se establece un modelo matemático para medir el impacto económico que un fallo crítico del sistema ocasionaría a la continuidad de las consultorías de la organización.

3.1. Proceso De Recolección De Información Y Planteamiento De Actividades

3.2. Aplicación De Instrumentos Para El Levantamiento De Información

3.2.1. Cuestionarios y Encuestas

Se aplicó una entrevista técnica semiestructurada a Alex Flores Valdez (Encargado de TI). Las respuestas críticas revelaron lo siguiente:

- **Esquema de redundancia:** No existe un arreglo RAID por hardware ni ZFS configurado para redundancia; los datos de las máquinas virtuales residen en discos duros mecánicos (HDD) individuales.
- **RespalDOS:** Los snapshots de PROXMOX se guardan en un disco secundario dentro del mismo chasis físico. No existen rutinas de copias de seguridad fuera del sitio (off-site) automatizadas.

3.2.2. Revisión de Documentación

3.2.3. Observación

Durante una jornada laboral estándar del área de Digitales, se evidenció lo siguiente:

- Los colaboradores acceden a los paneles de administración de Odoo y Jira dejando las sesiones activas en sus estaciones de trabajo cuando se ausentan de sus escritorios (ausencia de políticas de bloqueo de pantalla).

- Físicamente, el servidor principal carece de un entorno controlado (Data Center). Es un equipo ensamblado con apariencia de “PC Gamer” ubicado en una oficina de tránsito regular, expuesto a polvo, alteraciones accidentales de cableado y carente de una fuente de alimentación ininterrumpida (UPS) de grado empresarial.

3.3. Aplicación De Técnicas Y Herramientas Para El Levantamiento De Actividades

3.3.1. Matriz DAFO

Aplicada a la infraestructura local gestionada en PROXMOX:

- **Fortalezas:** El equipo de Digitales posee un nivel técnico excepcionalmente alto y un conocimiento profundo de la arquitectura del servidor. Cualquier miembro del área es capaz de realizar mantenimiento físico y reconfigurar el hipervisor sin depender de terceros.
- **Oportunidades:** El dominio del equipo sobre tecnologías de virtualización facilita una transición futura muy ágil hacia entornos Cloud o infraestructuras hiperconvergentes empresariales.
- **Debilidades:** El servidor físico utiliza hardware de consumo con Discos Duros Mecánicos (HDD). Esto genera un cuello de botella severo en el rendimiento de entrada/salida (I/O) y carece de la confiabilidad de grado servidor (ausencia de memoria ECC y fuentes redundantes).
- **Amenazas:** Alto riesgo de pérdida total de datos por desgaste y fallo inminente de los discos HDD bajo carga 24/7. Vulnerabilidad ante fluctuaciones del suministro eléctrico local que podrían corromper los sistemas de archivos de las VMs.

3.3.2. Matriz de Actividades

3.3.3. Matriz de Brechas

- **Estado Actual:** Servidor con hardware de consumo (HDD), sin redundancia de discos (No RAID), con hipervisor PROXMOX realizando respaldos locales dentro del mismo equipo físico.
- **Estado Deseado (Estándar ISO):** Servidor de grado empresarial con almacenamiento de estado sólido (SSD/NVMe) configurado en RAID 1 o 5. Esquema de backups automatizados bajo la regla 3-2-1 (3 copias, 2 medios distintos, 1 copia externa).

- **Brecha:** Alta. Se requiere urgente inversión en almacenamiento sólido e implementación de un protocolo de respaldos externo para proteger la continuidad operativa.

3.4. Valoración Del Riesgo

3.5. Matriz De Riesgo

3.6. Matriz De Probabilidad E Impacto

A partir del análisis de brechas e inspección técnica, se identificaron y valoraron los siguientes riesgos críticos de seguridad y operación en la infraestructura local:

1. Falla Mecánica Catastrófica del Almacenamiento (HDD):

- *Probabilidad:* Alta. *Impacto:* Crítico. *Nivel de Riesgo:* **INACEPTABLE** (Peligro inminente de pérdida irreversible de datos de clientes).

2. Corrupción de Datos por Corte Eléctrico en Servidor sin UPS:

- *Probabilidad:* Media. *Impacto:* Alto. *Nivel de Riesgo:* **MAYOR** (Daño potencial en los sistemas de archivos de las máquinas virtuales y bases de datos).

3. Vulneración Física o Accidental del Hardware (Ubicación Inadecuada):

- *Probabilidad:* Media. *Impacto:* Alto. *Nivel de Riesgo:* **MODERADO** (Riesgo de apagados accidentales, desconexiones o robo físico del equipo por estar en área común).

4. Acceso No Autorizado y Fuga de Credenciales por Sesiones Activas Desatendidas:

- *Probabilidad:* Alta. *Impacto:* Alto. *Nivel de Riesgo:* **MAYOR** (Pérdida de control de accesos a Jira, Odoo y repositorios debido a la falta de políticas de bloqueo automático).

5. Interceptación de Tráfico de Datos Sensibles (Man-in-the-Middle):

- *Probabilidad:* Media. *Impacto:* Alto. *Nivel de Riesgo:* **MAYOR** (Exposición de credenciales de Nextcloud y documentos en tránsito debido a la falta de HTTPS forzado por TLS/SSL).

3.7. Impacto Económico

La materialización de una falla de hardware o una brecha de seguridad grave detendría por completo los entornos locales de desarrollo y digitalización comercial. Se estima un Tiempo de Inactividad (*Downtime*) mínimo de 3 a 7 días hábiles para restablecer la operatividad.

Para cuantificar formalmente esta pérdida, se propone el siguiente modelo matemático para el cálculo del Costo de Inactividad ($C_{downtime}$):

$$C_{downtime} = P_{SLA} + (C_{HH} \times N \times T_d) + C_{rep}$$

Donde:

- P_{SLA} : Penalidades contractuales por incumplimiento de plazos con clientes (10 % a 15 % del valor de un contrato promedio de S/ 30,000, equivalente a S/ 4,500 por cliente afectado).
- C_{HH} : Costo promedio por hora-hombre de los desarrolladores y especialistas (S/ 25.00 soles).
- N : Número de colaboradores afectados e inactivos (12 integrantes en el área).
- T_d : Tiempo total de inactividad del sistema en horas (estimado en 48 horas laborables para una recuperación de 6 días).
- C_{rep} : Costo directo de reposición de hardware degradado y soporte externo de restauración (S/ 3,500 soles).

Reemplazando los valores en la ecuación para un escenario de fallo con un único cliente penalizado:

$$C_{downtime} = S/ 4,500 + (S/ 25,00 \times 12 \times 48) + S/ 3,500 = S/ 22,400,00 \text{ soles}$$

Este impacto económico representa una pérdida de liquidez inmediata del 56 % sobre el margen de utilidad esperado en un proyecto estándar de consultoría, justificando la inversión preventiva en hardware robusto redundante.

4. FASE IV: INFORME DE AUDITORÍA

Esta cuarta y última fase del proyecto consolida los resultados obtenidos y presenta la estructura del informe final dirigido a la alta gerencia de la organización. Abarca la redacción

de la carta de presentación formal, la introducción metodológica al informe final y la descripción pormenorizada de las principales observaciones o deficiencias identificadas. Asimismo, propone de forma estructurada un plan de acción correctivo y un plan de mejoras preventivas diseñados para reducir la exposición al riesgo del área de Digitales y asegurar la continuidad del negocio y el cumplimiento normativo.

4.1. Carta de presentación del informe

4.2. Introducción al informe final

4.3. Principales Observaciones

4.4. Plan de Acción

4.5. Plan de Mejoras

5. CONCLUSIONES

6. RECOMENDACIONES